

Users & permissions check

Ova skripta služi za proveru korisnika, privilegija i permisija fajlova na Linux sistemu. Cilj skripte je da pomogne pri otkrivanju potencijalno nesigurnih konfiguracija koje mogu predstavljati rizik za sistem.

Na početku se proveravaju korisnici koji imaju UID 0. Na Linux sistemima UID 0 označava root privilegije, pa svaki dodatni korisnik sa tim UID-em može predstavljati bezbednosni problem.

Nakon toga skripta prikazuje članove sudo i wheel grupa. Korisnici u tim grupama imaju administratorska ovlašćenja ili mogućnost izvršavanja komandi sa povišenim privilegijama, pa je važno proveriti da li postoje neočekivani korisnici u tim grupama.

Sledeća provera odnosi se na SUID i SGID fajlove. Ovi fajlovi omogućavaju izvršavanje programa sa privilegijama vlasnika ili grupe i često predstavljaju potencijalnu tačku za eskalaciju privilegija ukoliko su pogrešno podešeni ili ranjivi. Zbog velikog broja rezultata prikazuje se samo prvih 20 pronađenih fajlova.

Skripta zatim proverava world-writable fajlove i direktorijume. To su fajlovi ili folderi nad kojima svi korisnici imaju pravo upisa, što može omogućiti neovlašćene izmene ili ubacivanje malicioznog sadržaja.

Takođe se pretražuju authorized_keys fajlovi u /home direktorijumu. Ovi fajlovi sadrže SSH javne ključeve koji omogućavaju pristup bez lozinke, pa je korisno proveriti koji korisnici imaju podešen SSH pristup.

Na kraju skripta proverava permisije važnih sistemskih fajlova kao što su /etc/passwd, /etc/shadow i /etc/sudoers. Ovi fajlovi sadrže informacije o korisnicima, lozinkama i administratorskim privilegijama, pa nepravilne permisije mogu predstavljati ozbiljan bezbednosni problem.

Services & network check

Ova skripta služi za pregled aktivnih servisa, mrežnih konekcija i osnovnih mrežnih bezbednosnih podešavanja sistema. Cilj je da se dobije pregled procesa i servisa koji mogu biti dostupni preko mreže ili potencijalno izloženi spoljnim pristupima.

Prvi deo skripte prikazuje portove koji trenutno slušaju konekcije korišćenjem ss komande. Ovo omogućava pregled servisa koji su dostupni lokalno ili preko mreže i može pomoći pri otkrivanju nepotrebno otvorenih servisa.

Nakon toga prikazuju se aktivne mrežne konekcije kako bi se videlo koji procesi trenutno komuniciraju sa drugim sistemima. Ova provera može pomoći u otkrivanju neočekivane ili sumnjive mrežne aktivnosti.

Skripta zatim prikazuje pokrenute servise. Ako sistem koristi systemd, koristi se systemctl, a u suprotnom koristi se service komanda. Na taj način se dobija pregled aktivnih servisa koji rade u pozadini sistema.

Dalje se prikazuju procesi koji troše najviše memorije pomoću ps aux. Ovo može pomoći pri identifikaciji procesa koji opterećuju sistem ili eventualno izgledaju neuobičajeno.

Skripta proverava i firewall konfiguraciju preko ufw ili iptables alata. Firewall pravila su važna jer kontrolišu mrežni saobraćaj i određuju koji portovi i servisi su dostupni spolja.

Na kraju se proverava status SSH servisa i osnovna SSH konfiguracija iz sshd_config fajla. Posebno se proveravaju opcije kao što su PermitRootLogin, PasswordAuthentication i PubkeyAuthentication, jer one direktno utiču na način autentifikacije i bezbednost udaljenog pristupa sistemu.

System information check

Ova skripta služi za pregled osnovnih informacija o sistemu i proveru konfiguracija koje mogu imati uticaj na bezbednost i stabilnost Linux servera. Cilj skripte je da pruži kratak pregled stanja sistema i omogućiti lakše uočavanje potencijalnih problema u konfiguraciji.

Na početku skripta prikazuje hostname sistema kako bi se jasno identifikovao server na kojem se izvršava provera.

Nakon toga prikazuje se verzija operativnog sistema korišćenjem /etc/os-release fajla, kao i verzija kernela pomoću uname -a komande. Ove informacije su važne jer zastarele verzije sistema ili kernela mogu sadržati poznate ranjivosti koje više nisu podržane bezbednosnim zakrpama.

Skripta zatim prikazuje uptime sistema. Dugačak uptime može ukazivati na to da sistem dugo nije restartovan, što često znači da kernel ili pojedini servisi nisu ažurirani nakon instalacije sigurnosnih zacrpa.

Dalje se prikazuju trenutno prijavljeni korisnici korišćenjem who komande. Ova provera omogućava pregled aktivnih korisničkih sesija i može pomoći u otkrivanju neočekivanih prijava na sistem.

Skripta proverava i timezone i NTP status sistema. Tačno vreme i pravilna sinhronizacija vremena važni su za logovanje događaja, autentifikaciju i analizu bezbednosnih incidenata. Problemi sa vremenom mogu otežati praćenje aktivnosti i korelaciju logova između različitih sistema.

Nakon toga prikazuju se informacije o zauzeću diska pomoću df -h komande i pregled mountovanih particija. Ove informacije mogu pomoći pri identifikaciji neobičnih mount opcija ili nedostatka prostora na disku koji može uticati na rad sistema.

Skripta zatim proverava broj instaliranih paketa na sistemu. Veći broj nepotrebnih paketa povećava površinu napada sistema, pa je dobra praksa održavati samo minimalan broj potrebnih komponenti.

Na kraju se prikazuju cron direktorijumi i cron zadaci. Cron poslovi se izvršavaju automatski u određeno vreme i često rade sa povišenim privilegijama, pa je važno proveriti njihove dozvole i sadržaj kako bi se sprečilo izvršavanje neautorizovanih skripti.

Web & database configuration check

Ova skripta služi za pregled konfiguracije web i database servisa na Linux sistemu. Cilj skripte je da pomogne pri identifikaciji nesigurnih podešavanja web servera, PHP konfiguracije i baze podataka koja može biti izložena mreži ili nepravilno podešena.

Na početku skripta proverava da li su pokrenuti Apache, Nginx, MySQL ili MariaDB procesi. Ovi servisi predstavljaju ključne komponente web okruženja i često su meta napada, pa je važno znati da li su aktivni na sistemu.

Nakon toga prikazuju se otvoreni portovi povezani sa web i database servisima, konkretno portovi 80, 443 i 3306. Ova provera omogućava pregled servisa koji su dostupni preko mreže i može pomoći pri otkrivanju nepotrebno izloženih servisa.

Skripta zatim proverava Apache security konfiguraciju i prikazuje vrednosti ServerTokens i ServerSignature opcija. Ove opcije kontrolišu količinu informacija koje web server otkriva klijentima. Previše detalja o verziji servera može pomoći napadaču pri identifikaciji poznatih ranjivosti.

Dalje se proveravaju važne PHP opcije iz php.ini konfiguracije. Posebno se proveravaju opcije display_errors, log_errors, expose_php i allow_url_include. Prikazivanje grešaka korisnicima može otkriti osetljive informacije o aplikaciji, dok expose_php otkriva verziju PHP-a u HTTP headerima. Opcija allow_url_include može predstavljati ozbiljan sigurnosni rizik jer omogućava uključivanje udaljenog sadržaja u PHP kod.

Skripta proverava i permisije nad /var/www direktorijumom, kao i world-writable fajlove unutar web root direktorijuma. Previše liberalne permisije mogu omogućiti neovlašćene izmene sadržaja web aplikacije ili ubacivanje malicioznog koda.

Na kraju se proverava MySQL konfiguracija, odnosno bind-address opcija iz my.cnf fajla. Ako je baza podataka dostupna na svim mrežnim interfejsima umesto samo lokalno, povećava se mogućnost neovlašćenog pristupa bazi preko mreže.

Logging, Backup & Tasks check

Ova skripta služi za pregled konfiguracije logovanja, bezbednosti rezervnih kopija (backup) i zakazanih zadataka (cron) na Linux sistemu. Cilj je da se detektuju propusti koji bi napadaču omogućili brisanje tragova, pristup osetljivim arhivama ili eskalaciju privilegija.

Na početku se proverava status rsyslog servisa i njegova konfiguracija. Skripta analizira da li je konfigurisano slanje logova na udaljeni server. Ukoliko logovi nisu sačuvani na udaljenom sistemu, napadač ih može lako obrisati kako bi sakrio svoje tragove, pa je eksterno logovanje (pomoću parametra @servername) uvek preporučljivo za servere.

Zatim se proveravaju permisije nad backup direktorijumima. Česta greška administratora je ostavljanje ovih direktorijuma i njihovog sadržaja čitljivim za neprivilegovane korisnike. Na ovaj način napadač može preuzeti arhive i iz njih izvući osetljive fajlove, poput /etc/shadow.

Zbog toga je neophodno ograničiti pristup ovim podacima i osigurati da backup skripte pravilno postavljaju permisije.

Na kraju, skripta proverava korisničke zadatke u `/var/spool/cron/crontabs` direktorijumu, kao i ranjivost (world-writable status) skripti koje se pozivaju kroz cron. Veoma je važno proveriti permisije nad skriptama koje se automatski izvršavaju, jer ako bilo koji korisnik može da ih menja, napadač može ubaciti maliciozni kod i steći root pristup prilikom sledećeg automatskog pokretanja zadatka.

Advanced Security & Configuration check

Ova skripta dopunjuje osnovne provere i fokusira se na napredna bezbednosna podešavanja sistema koja se često previde.

Na početku se vrši provera IPv6 firewall pravila pomoću `ip6tables` alata, kao i provera da li su ta pravila trajna (persistentna), odnosno da li će se automatski primeniti nakon ponovnog pokretanja sistema čitanjem fajlova poput `/etc/iptables.up.rules`. Zatim se analizira `/etc/fstab` fajl kako bi se utvrdilo prisustvo bezbednosnih zastavica prilikom montiranja particija, kao što su `noexec`, `nosuid` i `noatime`. Ove opcije značajno smanjuju rizik od izvršavanja malicioznih fajlova i neovlašćene eskalacije privilegija.

Skripta takođe proverava `/etc/shadow` fajl kako bi identifikovala algoritme korišćene za enkripciju lozinki, upozoravajući na prisustvo zastarelih i ranjivih algoritama poput DES-a ili MD5. Na kraju, vrši se pregled naprednih SSH opcija u `sshd_config` fajlu. Konkretno, proverava se opcija `AllowTcpForwarding` koja bi trebalo da bude isključena kako bi se sprečilo korišćenje servera za zaobilaženje mrežnih restrikcija, kao i to da li se koristi podrazumevani SSH port koji je često meta automatizovanih napada.